

Filtrage réseau



C'est quoi un firewall ?



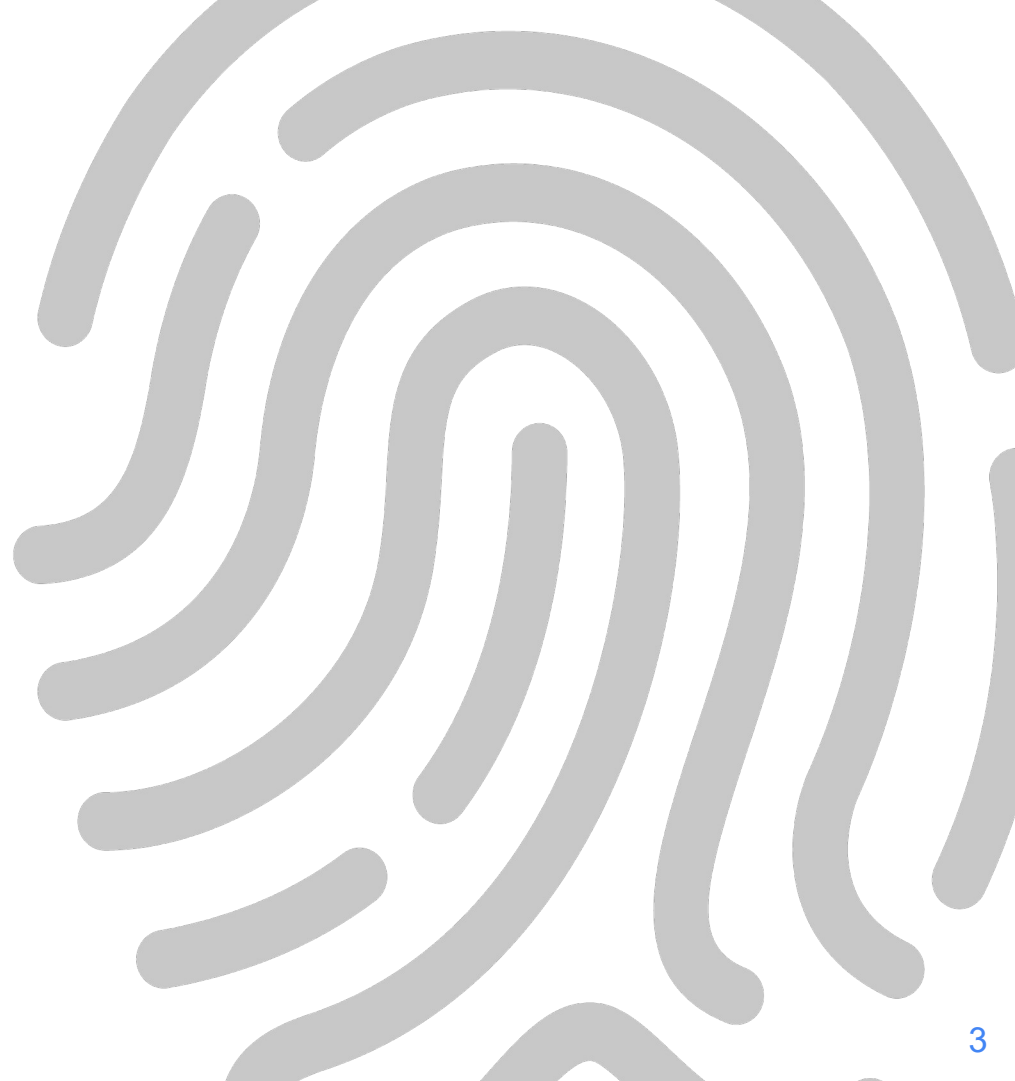
Plan

[1 - Introduction](#)

[2 - Sécurisation réseau](#)

[3 - Types de pare-feux](#)

[4 - En entreprise](#)





Introduction



Définition

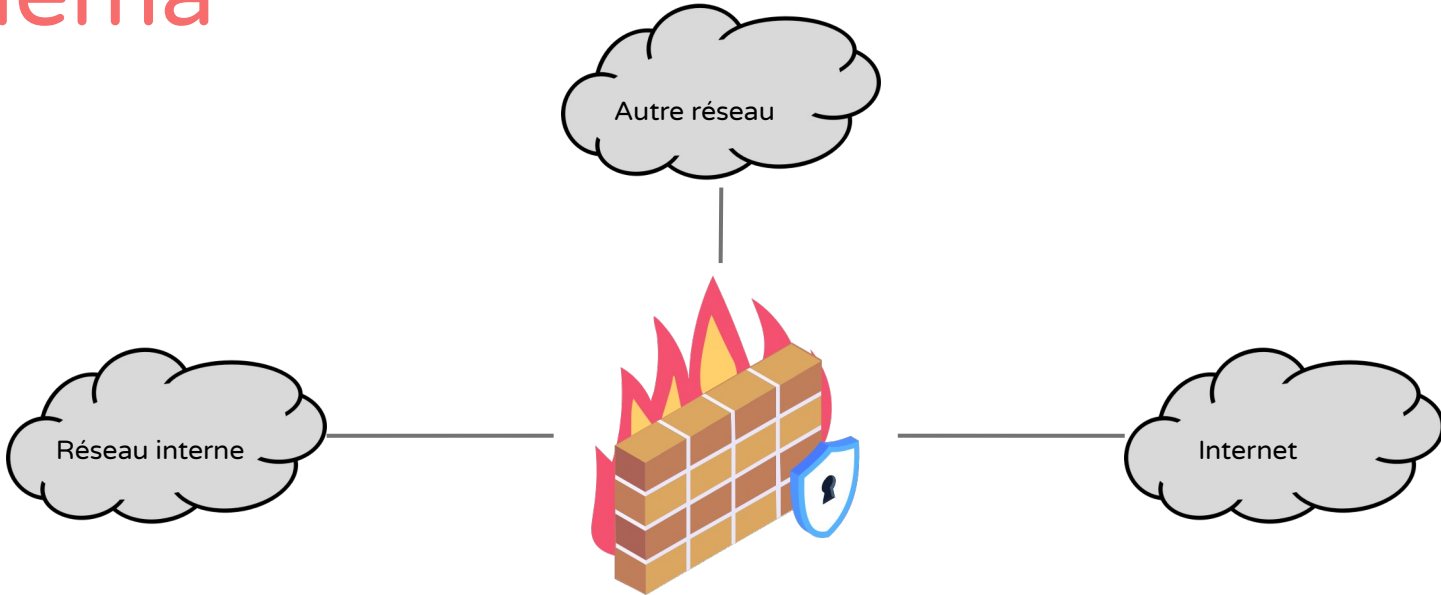
Pare-feu (*firewall*, garde-barrière, coupe-feu...)

- Noeud à l'intersection de réseaux (en coupure)
- Niveau 4 (au moins) - Transport (TCP, UDP...)
- Contrôle (filtre) les paquets qui le traversent
- Associé à des fonctions de routage

Objectif : fournir une connectivité contrôlée et maîtrisée entre des réseaux de différents niveaux de confiance



Schéma





Principe du filtrage

Inspecte les paquets entrants, sortants et traversants le firewall

Pour chaque paquet, déroule la pile protocolaire (au moins jusqu'au niveau 4)

Puis accepte (*accept*) ou refuse (*drop* ou *reject*) selon

- Les informations des en-têtes protocolaires
- Le format et le contenu des données
- Des comptes utilisateurs, informations temporelles...



Sécurisation réseau



Sécurité des systèmes

Tous les systèmes ont des failles de sécurité

Les configurations (notamment par défaut) peuvent comporter des défauts

De nombreux services réseaux inutiles sont activés par défaut

=> Besoin de sécurisation du réseau



Défense en profondeur

Sécuriser le réseau (idée générale)

=> Seul le trafic légitime entre et sort du réseau

Défense périmétrique

Recommandation : ne pas faire aveuglément confiance à nos défenses

=> Défense en profondeur



Politique de filtrage

2 approches :

- La liste de blocage : définir les paquets à bloquer
 - Inconvénients : on peut en oublier et peu d'alertes en cas d'échec
 - Approche non recommandée
- La liste d'autorisation : Principe de base
 - Tout bloquer (**deny all**)
 - Autoriser uniquement les communications légitimes



Zones de confiance

Segmentation du réseau en zones de confiance

=> Regrouper tous les noeuds ayant les mêmes besoins en sécurité

Le filtrage peut se faire entre zones de confiance

Souvent associé à un cloisonnement des réseaux physiques

- Physiquement ou VLAN

Matrice des flux (filtrage) : Communications légitimes entre chaque zones



DMZ

De nombreuses zones peuvent être fortement filtrées

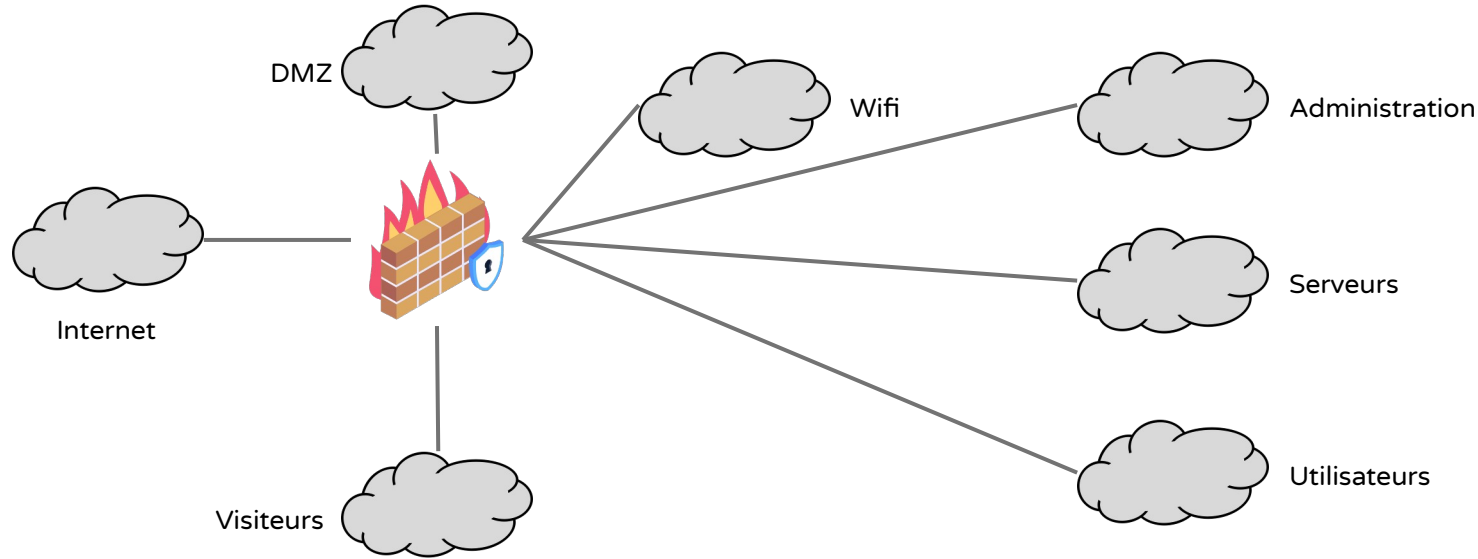
- Par ex. : pour l'ensemble des machines clientes => sortie uniquement

Certains serveurs doivent être accessibles depuis l'extérieur (mail, web...)

- Ils sont placés dans des zones appelées DMZ (*DeMilitarized Zone*)
- Surveillance et filtrage spécifique
- Peuvent être des points d'entrées dans le réseau



Un exemple





Types de pare-feux



Pare-feu sans état

Stateless firewall - filtrage simple

- Règles simples basées sur les entêtes protocolaires
 - Adresses source et/ou destination
 - Ports (UDP, TCP)
 - Protocoles utilisés
 - Options...
- Rapide et efficace
- Limites :
 - Chaque paquet traité indépendamment
 - Règles complexes et/ou nombreuses



Pare-feu à états

Statefull firewall

- Suivi des connexions des protocoles à états (TCP)
 - Vérifie la conformité d'un paquet dans son contexte
 - Autorisation implicite des réponses
- Permet un filtrage plus poussé
- Allège l'écriture des règles
- Limites :
 - Nécessite plus de ressources (mémoire, CPU...)



Pare-feu applicatif

Deep Packet Inspection (DPI)

- Déroule l'intégralité de la pile protocolaire - examine les données
- Vérifie la conformité du paquet avec les protocoles utilisés
- Permet le filtrage de protocoles *difficile* (ex : FTP)
- Nécessite une connaissance du protocole applicatif
- Inconvénient : *impossible* dans le cas de chiffrement de bout en bout
- Spécialisation
 - Les WAF (*Web Application Firewall*) spécialisé dans HTTP



Pare-feux personnels

Logiciel filtrant le trafic entrant/sortant d'une unique machine

- Avantage : permet un filtrage interactif
- Un service parmi d'autre => moins sûr



En entreprise



Critères de sélection

Disclaimer : Il n'y a pas de solution meilleure universellement qu'une autre. Tout est une question d'adéquation avec les besoins métier, la roadmap technique et la stratégie de sécurité.

Critères possibles :

- Complexité de l'infrastructure
- Intégration avec l'existant
- Budget et performances nécessaires
- Compétences en interne pour la gestion
- Orientation Cloud/Hybride



Check Point

Points forts :

- Expertise historique en sécurité (90's, pionnier du *stateful inspection*)
- Gestion unifiée (plateforme de gestion R80)
- Prévention des menaces consolidée (global AI : *ThreatCloud*)

Idéal pour :

Grands comptes sensibles à la conformité et à la prévention des cyberattaques avancées.



Fortinet (Fortigate)

Points forts :

- Rapport performance/prix
- Suite de sécurité unifiée (Fortinet Security Fabric)
- Gestion centralisée avec FortiManager

Idéal pour :

PME/ETI, multi-sites, et ceux cherchant une protection complète sans multiplier les solutions.



Cisco ASA (avec FirePower)

Points forts :

- Intégration réseau native
- Écosystème Cisco étendu
- Fiabilité éprouvée

Idéal pour :

Les environnements Cisco existants, les grands groupes avec des besoins de sécurité avancés et de segmentation fine.



Palo Alto Networks

Points forts :

- Détection avancée des menaces (WildFire sur cloud)
- Politique sécurité basée sur les applications (App-ID : sign. et heuristique)
- Vision claire du trafic

Idéal pour :

Entreprises voulant une visibilité applicative fine et une protection contre les menaces zero-day.

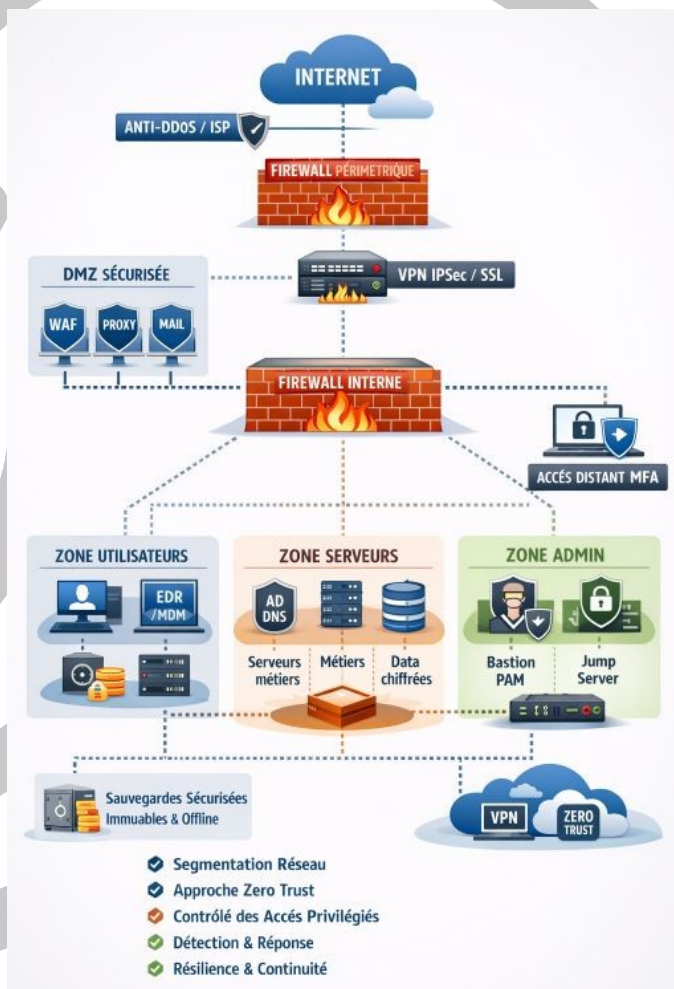


Point d'attention

La cybersécurité ne se résume plus à un firewall ou à un antivirus.

Elle repose aujourd'hui sur une architecture pensée pour **résister**, **détecter**, **contenir** et **se relever** face aux attaques.

=> Approche "Security by Design & Resilience by Default", alignée avec les attentes des RSSI, DSI et Directions Générales.





Conclusion

- Notion de pare-feu
- Architecture réseau, zones de confiance et DMZ
- Différents types de pare-feux